

ÉTUDE DE CAS — SPOTIFY

LIVRABLE 3

Plan de mise en œuvre de la gouvernance

Certification RNCP 41993 – Adrien COSSON

Bloc 1 - Concevoir et piloter la gouvernance des données et des systèmes d'IA

1. Introduction

Le Livrable 1 a situé la maturité de Spotify à environ 2,7 sur 5, entre les niveaux « Reactive » et « Proactive ». Le Livrable 2 a fixé les règles pour y remédier : neuf principes, une classification des données et des rôles clairs. Ce troisième livrable explique comment passer de la politique à la pratique : quel modèle d'organisation retenir, avec quels outils, et sur quel périmètre tester le cadre avant de l'étendre à toute l'entreprise.

Notre choix est de commencer par un pilote centré sur les **demandes d'accès et de suppression des utilisateurs (DSAR) et le consentement**, limité aux utilisateurs résidant en Suède. Ce choix découle directement du diagnostic, comme nous l'expliquons en section 4.

2. Modèle organisationnel : le Centre d'Excellence

Le document « *Organizational Models* » présente trois façons d'organiser la donnée. Nous les avons comparées à la situation de Spotify :

- **Le modèle centralisé** est simple à mettre en place, mais l'équipe data devient une fonction support : les métiers ne s'approprient pas leurs données et l'équipe centrale ne suit plus le rythme des demandes. Avec plus de 180 pays et des équipes très autonomes, ce goulot serait inévitable.
- **Le modèle embarqué** correspond à peu près à la situation actuelle de Spotify. Chaque équipe est agile et proche du métier, mais ce modèle crée des silos et ne fournit pas de source de vérité unique. C'est précisément ce que le Livrable 1 a mis en évidence (C1) avec l'existence des silos et le problème de traçabilité des données et duplication de celle-ci.
- **Le Centre d'Excellence (CoE)** combine les avantages des deux : une équipe centrale fixe les standards et fournit les outils, et les équipes métier restent responsables de leurs données. Son principal défaut, une couche de coordination supplémentaire, est acceptable pour une entreprise de la taille de Spotify. Il est d'ailleurs déconseillé aux petites et moyennes structures, ce que Spotify n'est pas.

Nous retenons donc le CoE, conformément à la recommandation de l'Executive Q&A Guide. Concrètement, l'équipe centrale est placée sous l'autorité du CDO, qui rapporte à la direction générale ; chaque département cité dans le business case (marketing, développement produit, curation de contenu, ingénierie) a un Data Owner et un ou plusieurs Data Stewards ; le Comité de gouvernance, qui réunit des représentants de ces départements, arbitre chaque mois. L'organigramme détaillé figure dans le Livrable 2b.

3. Outils

Nous avons sélectionné les outils à partir du Tech Tools Overview, en retenant un outil par besoin plutôt qu'une liste. Le business case indique que Spotify utilise déjà des Data Lakes, des bases relationnelles et du stockage cloud : chaque outil fera donc l'objet d'une courte preuve de concept (PoC) pour vérifier qu'il s'intègre à cet existant avant tout achat.

- **Conformité : OneTrust.** C'est l'outil central du pilote. Il cartographie les données personnelles, gère le consentement et automatise le traitement des demandes d'accès et de suppression. Nous l'avons préféré à TrustArc et VeraSafe pour sa couverture du RGPD et du CCPA dans un même outil.
- **Catalogue : Collibra.** Il documente chaque jeu de données (propriétaire, sensibilité, provenance) et sert d'outil de travail aux Data Stewards. Il est conçu pour les grandes organisations. Apache Atlas, open source, reste une alternative moins coûteuse si la PoC montre une meilleure intégration.
- **Qualité : Ataccama ONE.** Il automatise le profilage et les contrôles de qualité à grande échelle, ce qui correspond aux volumes traités en temps réel par Spotify. Ces contrôles appliquent les seuils fixés dans les data contracts (principe 4).
- **Sécurité : Splunk et Vormetric.** Splunk centralise les journaux d'accès et détecte les incidents ; Vormetric chiffre les données sensibles et gère les clés. Les contrôles d'accès RBAC et ABAC s'appuient sur les étiquettes de classification du catalogue.

Deux briques ne figurent pas dans le Tech Tools Overview mais sont nécessaires au plan. D'abord, un **identifiant utilisateur commun**, développé en interne, qui relie les données d'un même utilisateur entre les systèmes (C1). Ensuite, un registre de modèles comme **MLflow**, qui associe chaque modèle d'IA à ses données d'entraînement et à ses tests de biais, pour appliquer le principe 9 lors de la vague 3.

4. Pilote : demandes des utilisateurs et consentement en Suède

4.1 Pourquoi ce pilote

Le Pilot Template propose de tester le cadre sur un département ou sur un jeu de données. Nous avons choisi un jeu de données : **les données personnelles des utilisateurs résidant en Suède**, pour trois raisons.

La première est que le risque est réel : en 2023, l'IMY, l'autorité suédoise, a sanctionné Spotify parce que ses réponses aux demandes d'accès étaient incomplètes et peu compréhensibles. La deuxième est que le résultat se mesure facilement (délai de réponse, complétude, automatisation). La troisième, la plus importante, est que ce pilote oblige à construire les fondations de la gouvernance. Pour répondre complètement à une demande d'accès, il faut savoir où se trouvent les données d'un utilisateur, lesquelles sont personnelles, et comment les relier entre les systèmes. Le pilote traite ainsi en même temps les trois défis prioritaires du Livrable 1 : les silos (C1), les droits des utilisateurs (C2) et la documentation des données (C3).

4.2 Objectifs et périmètre

Les objectifs reprennent les quatre buts du Pilot Template, appliqués à notre périmètre :

- **Qualité** : fiabiliser les profils utilisateurs, avec un identifiant unique et sans doublons entre systèmes.
- **Conformité RGPD** : traiter les demandes d'accès, de suppression et de portabilité dans les délais, et synchroniser le consentement entre tous les systèmes.
- **Accès et intégration** : cataloguer et étiqueter toutes les données personnelles du périmètre.
- **Réduction des risques** : appliquer les contrôles d'accès selon la classification du Livrable 2 (Public ; Interne ; Confidentiel ou Restreint).

Le périmètre couvre six systèmes : le compte et le profil, l'historique d'écoute, les profils de recommandation, les données marketing et publicitaires, l'abonnement (le paiement restant chez le prestataire) et le support client.

4.3 Équipe

A partir du « *Pilot Template* », l'équipe reprend les rôles, adaptés à un périmètre qui traverse plusieurs départements.

- Un **chef de projet**, rattaché au CDO, coordonne le pilote et rend compte au Comité.
- Le **DPO** garantit la conformité et valide les réponses aux utilisateurs.
- Les **Data Owners** des départements concernés (dont le Marketing Director et les Product Managers) jouent le rôle de « Department Head » : ils valident les finalités et les accès.
- Des Data Stewards, un par département concerné par le pilote (marketing, développement produit et ingénierie), impliqués dans la qualité et la documentation des données de leur périmètre.
- Enfin, un ou plusieurs **Data Engineers** mettent en place les outils et l'automatisation, avec l'appui de l'équipe du Head of Engineering.

4.4 Calendrier

Le pilote dure 6 mois, dans la fourchette de 3 à 6 mois indiquée par l'*Executive Q&A Guide*. Les jalons suivent ceux du « *Pilot Template* » :

Mois	Jalon	Contenu	Responsable
M1	Lancement	Réunion de lancement, mesure de la situation de départ (délai actuel de réponse aux demandes, nombre de réclamations), inventaire des systèmes	Chef de projet
M2	Évaluation des données	Catalogage des systèmes, étiquetage des données personnelles, nettoyage des doublons	Data Stewards
M3	Intégration technique	Identifiant utilisateur commun, connexion des systèmes à OneTrust, synchronisation du consentement ; revue à mi-parcours	Data Engineers
M4	Audit RGPD/CCPA	Audit du DPO sur les traitements du périmètre, vérification des bases légales	DPO
M5	Exploitation	Traitement des vraies demandes des utilisateurs par la nouvelle chaîne, tests avec de faux comptes	Data Engineer
M6	Bilan	Mesure des indicateurs, retours des équipes, décision de généralisation par le Comité	Chef de projet

Un point mensuel avec le Comité permet de suivre l'avancement, de remonter les blocages et de décider du passage à l'étape suivante.

4.5 Livrables du pilote

Le pilote produit les cinq livrables du « *Pilot Template* » :

- Un **rapport de qualité** (amélioration des profils par rapport au mois 1)
- Une **évaluation de conformité** RGPD et CCPA (issue de l'audit du mois 4)
- Un **plan d'intégration technique** (comment les systèmes ont été reliés et documentés)
- Un **rapport de risques** mis à jour au bilan
- Et enfin une **synthèse des retours** des équipes et des utilisateurs.

4.6 Indicateurs de succès

Les indicateurs (KPI, Key Performance Indicators) suivent les quatre familles du « *Pilot Template* ». Les cibles sont fixées par rapport à la mesure faite au mois 1 :

- **Qualité** : réduction de 10 % des champs manquants dans les profils utilisateurs par rapport au mois 1, et aucun doublon entre systèmes pour un même utilisateur.
- **Conformité** : 100 % des traitements du périmètre avec une base légale ou un consentement documenté ; délai médian de réponse aux demandes inférieur ou égal à 15 jours (le délai légal est d'un mois) ; 100 % des systèmes du périmètre couverts dans les réponses.
- **Accès** : réduction de 20 % du temps nécessaire à un utilisateur autorisé pour accéder à une donnée ; 100 % des jeux de données catalogués avec un propriétaire.
- **Risques et adoption** : 100 % des données personnelles étiquetées et protégées selon leur niveau ; moitié moins de réclamations liées aux demandes d'accès ; 100 % de l'équipe formée avant le mois 3.

4.7 Coût et valeur

Comme le rappelle l'*Executive Q&A Guide*, les coûts portent sur trois postes : les outils (en premier lieu les licences OneTrust et Collibra), la formation et le personnel (le temps consacré par les Data Stewards et l'équipe technique). Le budget précis sera établi au lancement du pilote par le CDO, à partir de la mesure de la situation de départ. En face, l'amende de 2023 représentait à elle seule environ 5 M€, et le RGPD prévoit jusqu'à 4 % du chiffre d'affaires mondial. Surtout, le catalogue, les étiquettes et l'identifiant commun construits pendant le pilote seront réutilisés par toutes les étapes suivantes.

5. Gestion des risques

Les quatre premiers risques sont ceux du « *Pilot Template* » ; les trois suivants sont propres à notre pilote.

- **Non-conformité RGPD/CCPA** (probabilité moyenne, impact élevé) : audit du DPO au mois 4 et formation des équipes. Responsable : DPO.
- **Résistance au changement** (probabilité élevée, impact moyen) : ateliers, recueil des retours dès le début, Data Stewards comme relais. Responsable : chef de projet.
- **Problèmes de qualité non résolus** (probabilité faible, impact élevé) : contrôles automatiques et revue mensuelle. Responsable : Data Stewards.
- **Échec de l'intégration technique** (probabilité moyenne, impact élevé) : équipe du Head of Engineering associée dès le mois 1 et PoC des outils. Responsable : Data Engineers.
- **Anciens systèmes impossibles à relier à l'identifiant commun** (probabilité élevée, impact moyen) : table de correspondance provisoire et exception inscrite au catalogue. Responsable : Data Engineers.
- **Données d'un utilisateur oubliées lors d'une suppression** (probabilité moyenne, impact élevé) : une donnée supprimée dans un système peut rester dans un autre, par exemple dans les données qui servent à entraîner le moteur de recommandation. Mesure : la suppression est envoyée automatiquement à tous les systèmes reliés à l'identifiant commun, et vérifiée lors des tests du mois 5. Responsable : Data Engineer.
- **Surcharge des Data Stewards** (probabilité moyenne, impact élevé) : leur temps dédié (25 %) est inscrit dans leurs objectifs annuels. Responsable : Data Owners.

6. Formation et conduite du changement

Le business case insiste sur la culture data comme facteur de succès. Cette culture existe chez Spotify, mais chaque département l'a développée de son côté : le Livrable 1 a montré qu'il n'existe aucun programme commun de formation à la gouvernance (C7). Nous prévoyons trois niveaux :

- Un module court et obligatoire pour tous les collaborateurs, sur les règles de la politique et les bons réflexes (vie privée, qualité, accès).
- Des ateliers pratiques pour les équipes du pilote, comme le prévoit le « *Pilot Template* » : utilisation du catalogue, traitement d'une demande d'accès, étiquetage des données.
- Des parcours spécialisés ensuite : Data Stewards, équipes techniques, équipes produit et marketing.

Une documentation, des tutoriels et un support (helpdesk) accompagnent la formation, et un questionnaire mensuel recueille les retours des équipes. Les supports sont conçus pour être accessibles à tous, y compris aux personnes en situation de handicap (respect du RGAA : sous-titres, transcriptions, documents lisibles par synthèse vocale), et sont proposés en plusieurs langues pour tenir compte de la présence internationale de Spotify.

7. Évaluation, audits et veille

À la fin du pilote, le Comité évalue les résultats par rapport aux indicateurs, documente ce qui a fonctionné et ce qui a posé problème, et ajuste la politique si nécessaire. Au-delà du pilote, le contrôle repose sur trois niveaux d'audit : un suivi mensuel des indicateurs par les Data Stewards, un audit de conformité du DPO deux fois par an, et un audit externe annuel (RGPD et PCI-DSS). La veille réglementaire (RGPD, CCPA, AI Act) est assurée par le DPO et l'équipe juridique, la veille technologique par le CoE ; toutes deux sont présentées au Comité chaque trimestre.

8. Déploiement après le pilote

Si le bilan est positif, le cadre est étendu en deux vagues, sur 12 à 18 mois comme le prévoit l'*Executive Q&A Guide* :

- **Vague 2 (mois 7 à 12)** : extension à toute l'Union européenne et aux États-Unis (CCPA) ; data contracts sur les données de recommandation et les métadonnées de contenu (C4) ; contrôles d'accès par étiquette sur l'ensemble des données (C5).
- **Vague 3 (mois 13 à 18)** : extension aux autres pays, chacun possédant sa propre réglementation (par exemple le PDPA à Singapour, cité dans le « *business case* ») et gouvernance de l'IA : registre des modèles, revue des biais avant chaque mise en ligne, signalement des contenus générés par IA (C6).

À l'issue de ces trois étapes, l'objectif est d'atteindre le niveau « Managed », soit environ 4 sur 5.

9. Conclusion

Ce plan fait le lien entre le diagnostic et la politique. Le CoE apporte une organisation adaptée à la taille de Spotify, les outils sont choisis pour leur rôle précis, et le pilote sur les demandes des utilisateurs en Suède traite d'abord le risque le plus concret, tout en construisant les bases dont le reste du déploiement aura besoin. La suite dépendra des résultats mesurés au sixième mois : c'est au Comité de décider, sur ces résultats, d'étendre le cadre à toute l'entreprise.

Annexe : du constat à l'action

Défi (L1)	Principes (L2)	Action (L3)	Indicateur
C1 · Silos	1, 7	Identifiant commun (pilote)	Doublons entre systèmes
C2 · Droits et consentement	2, 5, 6, 7	Pilote DSAR et consentement	Délai et complétude des réponses
C3 · Documentation	1, 4	Catalogue et étiquetage (pilote)	% de jeux catalogués
C4 · Qualité	4	Data contracts (vague 2)	% de champs manquants
C5 · Sécurité	3	Accès par étiquette, chiffrement (vague 2)	% d'accès revus
C6 · IA	9	Registre des modèles, revue des biais (vague 3)	% de modèles revus
C7 · Formation	8	Programme de formation (continu)	% de collaborateurs formés